Déverrouillage Windows par téléphone

Cahier des charges fonctionnel et technique

Version 1.1 • 12 octobre 2026 • Usage personnel gratuit avec compte Microsoft et réseau public

Besoin exprimé

À l'écran de connexion de son PC, l'utilisatrice souhaite utiliser l'empreinte de son téléphone pour ouvrir sa session sans saisir son code PIN Windows à chaque fois. La solution doit également fonctionner après un verrouillage et, sur la configuration validée, après un redémarrage.

Orientation retenue

Concevoir une application Android et un composant Windows qui communiquent sur le réseau local. Le téléphone autorise une opération cryptographique après validation biométrique. Windows vérifie cette autorisation, puis utilise un mécanisme de connexion effectivement accepté par le système.

La cible est désormais le compte Microsoft personnel de l'utilisatrice, avec réseau en profil Public et Hyper-V désactivé. Windows 11 x64 et Android 11 ou plus récent restent à vérifier. VS Code est l'éditeur retenu ; aucun achat ni changement de type de compte ne sont imposés.

Point déterminant : le support du compte Microsoft doit être démontré avant l'installation de l'option de connexion. La piste utilisant un mot de passe chiffré exige un mot de passe encore existant et un chemin accepté par Windows ; un PIN ou une signature du téléphone ne suffisent pas.

Repères de lecture

Partie	Chapitres
Besoin et faisabilité	1 à 2
Fonctions et parcours	3 à 5
Architecture et authentification	6 à 8
Données et sécurité	9 à 10
Qualité et exploitation	11 à 12
Recette et réalisation	13 à 16
Références et compléments	17 à 18

Statut : version adaptée aux contraintes indiquées le 12 octobre 2026. Le développement vise zéro dépense supplémentaire ; la compatibilité de la connexion Microsoft reste à prouver. Les charges sont des estimations initiales.

1 Objectifs et périmètre

Objectifs du produit

- Ouvrir volontairement la session Windows depuis le téléphone associé, après une validation biométrique fraîche.
- Éviter la saisie répétée du PIN Windows pendant l'usage quotidien.
- Fonctionner sans serveur Internet pour l'association et le déverrouillage sur le réseau local.
- Maintenir une méthode Windows de secours et permettre la révocation immédiate d'un téléphone perdu.

Périmètre de la première version

Élément	Choix de cadrage
PC	Windows 11 Home ou Pro x64, version encore prise en charge au déploiement.
Compte	Compte Microsoft personnel conservé ; SID lié à l'identité ; support soumis au jalon Microsoft.
Téléphone	Android 11 ou plus récent ; biométrie forte utilisable avec une clé protégée matériellement.
Association	Un téléphone pour un compte sur un PC ; plusieurs associations prévues dans le modèle de données.
Connexion	Wi-Fi en profil Public conservé ; accès au téléphone par règle spécifique et canal authentifié.
Scénarios	Connexion interactive, verrouillage manuel et reprise de veille, redémarrage sur la configuration certifiée.
Interface	Français ; navigation accessible ; application mobile ouverte pendant l'opération.

Éléments hors première version

iPhone, Windows ARM, comptes Active Directory et Microsoft Entra ID, RDP, demandes UAC et connexions par Internet restent hors première version. Le compte Microsoft personnel est maintenant la cible de la preuve de faisabilité ; son support effectif n'est pas encore validé. Hyper-V est exclu.

Le déverrouillage du BIOS, de BitLocker avant le démarrage de Windows et du téléphone lui-même est exclu. Le PC doit être allumé et Windows arrivé à son écran de connexion ; le produit ne promet pas d'allumer le PC à distance.

Rôles

L'utilisatrice assure le développement, les tests et la maintenance. Les responsabilités Windows, Android, protocole et sécurité doivent être vérifiées séparément même si une seule personne les assume. Une relecture extérieure bénévole peut aider ; aucun prestataire payant n'est exigé.

2 Faisabilité et décisions techniques

Constats vérifiés

Microsoft documente l'ajout de Credential Providers pour présenter une nouvelle option de connexion. Ces composants recueillent et sérialisent des identifiants ; la décision finale d'authentification appartient aux composants de sécurité Windows. [S1]

Microsoft recommande de garder au moins un fournisseur d'identifiants système utilisable. L'extension doit donc coexister avec la connexion Windows habituelle. Le remplacement ou l'encapsulation du fournisseur système n'est pas l'approche retenue. [S1]

L'ancien Windows Hello Companion Device Framework est déprécié depuis Windows 10 version 2004. Il ne doit pas servir de fondation à ce nouveau projet. [S2]

Le verrouillage dynamique verrouille le PC selon le signal du téléphone. Il ne répond pas au besoin d'ouverture de session. La documentation générale des passkeys concerne les sites et applications ; elle ne démontre pas une solution universelle pour une session Windows locale. [S7, S8]

Options de réalisation

Option	Conséquence	Décision
Application ou page web seule	Pas de composant disponible avant ouverture de session.	Insuffisant
Credential Provider et secret local protégé	Piste Microsoft avec mot de passe existant ; compatibilité Windows à démontrer.	À valider
Authentification Windows sans secret réutilisable	Intégration adaptée au type de compte, certificat ou mécanisme système à étudier.	Étude distincte
Lecteur biométrique Windows compatible	Alternative simple au développement ; n'utilise pas le téléphone.	Alternative de repli

Jalon obligatoire avant développement complet

Le prototype doit démontrer la connexion et le déverrouillage du compte Microsoft ciblé, avec méthode Windows de secours disponible. Vérifier réseau avant connexion, mot de passe ou mode sans mot de passe, option Hello uniquement, protections de code et fonctionnement avec ou sans Internet. Aucun recours à Hyper-V.

Si Windows n'accepte pas ce mécanisme sur le compte Microsoft avec les protections conservées, le jalon est refusé et l'architecture doit être revue. Le compte principal n'est pas converti en compte local pour contourner cet échec. Une simulation du résultat dans une application ne valide pas une vraie ouverture de session.

3 Exigences fonctionnelles

Priorités : P0 = indispensable à la première version ; P1 = amélioration ultérieure. Chaque exigence P0 doit être démontrée lors de la recette.

ID	Exigence	Priorité
F01	Diagnostiquer la compatibilité Windows, du compte, de la biométrie et du réseau avant association.	P0
F02	Installer le service et la nouvelle option de connexion avec droits administrateur et retour arrière.	P0
F03	Associer les appareils via QR code temporaire et comparaison d'un code sur les deux écrans.	P0
F04	Lier le téléphone au PC et au SID du compte choisi, après vérification de l'identité Windows.	P0
F05	Afficher une tuile « Téléphone » sur l'écran de connexion pour le compte associé.	P0
F06	Créer une demande explicite et limitée dans le temps depuis la tuile Windows.	P0
F07	Afficher PC, compte et demande sur le mobile avant toute validation.	P0
F08	Exiger une biométrie forte et une opération de signature liée à cette demande.	P0
F09	Vérifier la preuve et ne soumettre les identifiants à Windows qu'une seule fois.	P0
F10	Recevoir le résultat Windows et distinguer autorisation du téléphone et session réellement ouverte.	P0
F11	Permettre annulation, expiration et reprise sans blocage des autres options Windows.	P0
F12	Révoquer une association depuis le PC après authentification Windows récente.	P0
F13	Gérer perte de clé, changement de mot de passe et réassociation.	P0
F14	Afficher un historique local minimal et proposer son effacement.	P0
F15	Installer, mettre à jour et désinstaller sans supprimer les méthodes de secours.	P0
F16	Ajouter Bluetooth, plusieurs téléphones ou une notification mobile.	P1

Règles communes

Une association ne donne accès qu'au compte explicitement autorisé. Une demande ne doit jamais changer de compte après sa validation. Le simple voisinage du téléphone, son déverrouillage ou une ancienne authentification biométrique ne déclenchent aucune ouverture de session.

4 Parcours utilisateur et récupération

Première association

1. Ouvrir la session Windows normalement et lancer l'assistant de configuration. Vérifier qu'une connexion Windows de secours fonctionne.
2. Après validation du prototype Microsoft, installer les composants et sélectionner le compte lié. Toute utilisation de son mot de passe doit être explicitement acceptée ; aucun PIN Windows n'est collecté. L'association réseau peut être testée avant installation du fournisseur.
3. Vérifier qu'un mot de passe Microsoft existe encore et qu'un chemin de connexion compatible est disponible. Expliquer le risque de conserver ce secret sur le PC. Le mode sans mot de passe et Hello uniquement exigent une étude, sans modification automatique.
4. Afficher un QR code valable 120 secondes contenant l'identifiant du PC, son identité cryptographique et un jeton aléatoire d'association à usage unique.
5. Scanner le QR avec l'application Android, générer les clés du téléphone et comparer un code de six chiffres affiché sur les deux appareils.
6. Confirmer sur les deux appareils. L'échange authentifié lie les clés publiques, le PC et le compte. Supprimer le jeton puis effectuer un essai de déverrouillage.

Déverrouillage quotidien

1. À l'écran Windows, choisir le compte puis l'option « Téléphone » et cliquer sur « Demander le déverrouillage ».
2. Ouvrir l'application mobile, choisir le PC et récupérer la demande active sur le canal authentifié.
3. Vérifier le nom du PC, le compte et le code de correspondance ; appuyer sur « Autoriser ».
4. Valider la biométrie. La clé du téléphone signe la demande ; le service PC vérifie la preuve et la liaison à la session.
5. Windows accepte ou refuse les identifiants soumis. Le téléphone affiche le résultat final reçu, ou précise qu'il est inconnu si la connexion a été interrompue.

Téléphone perdu ou remplacé

Se connecter au PC avec la méthode Windows de secours, révoquer l'ancien téléphone et annuler toutes les demandes en cours. Associer le nouveau téléphone comme un nouvel appareil ; ne pas restaurer automatiquement une clé depuis une sauvegarde mobile.

Mot de passe ou biométrie modifiés

Un mot de passe Windows obsolète suspend la fonction après un échec de soumission ; aucune boucle de tentatives automatiques. Après une connexion Windows normale, l'utilisatrice met à jour le secret par l'assistant. Une clé mobile invalidée exige une nouvelle association ; la méthode Windows habituelle reste disponible.

5 Interfaces et comportements attendus

Écrans du PC

Écran	Contenu et actions
Assistant	Compatibilité, compte choisi, information sur les secrets, secours, QR code, code de comparaison et essai final.
Connexion Windows	Tuile Téléphone, compte actif, bouton Demander, code de correspondance, temps restant, Annuler et indications de secours.
Paramètres	Téléphone associé, date d'association, état du service, Révoquer, actualisation du secret et diagnostic local.
Historique	Date, résultat et cause lisible ; effacement et export manuel expurgé pour assistance.

Écrans du téléphone

Accueil avec le PC associé et son état ; lecture QR pendant l'association ; confirmation du code ; détail d'une demande ; dialogue biométrique système ; résultat final ; suppression de l'association. Les noms fournis par le PC sont traités comme du texte non fiable et leur longueur est limitée.

Libellés principaux

- « Autoriser la connexion à [PC], compte [compte] » avant la biométrie.
- « Autorisation envoyée, attente de Windows » tant que le résultat système n'est pas reçu.
- « Session ouverte » uniquement après un résultat de connexion positif.
- « Demande expirée. Crée une nouvelle demande sur le PC. »
- « PC inaccessible. Vérifie le réseau local ou utilise une autre option de connexion Windows. »
- « Le mot de passe Windows enregistré doit être actualisé. Connecte-toi normalement pour le mettre à jour. »

Accessibilité et consentement

Navigation clavier sur le PC, libellés accessibles aux lecteurs d'écran, contraste lisible, taille de texte mobile adaptable et information jamais transmise uniquement par une couleur. Les dialogues biométriques sont ceux du système Android ; aucune imitation de capteur d'empreinte dans l'application.

Le produit demande seulement les autorisations nécessaires : réseau et caméra pour le QR code. La caméra est facultative après l'association. Les notifications et Bluetooth ne sont pas requis en première version. Un refus de permission produit une explication et laisse la méthode Windows de secours utilisable.

Limite de la promesse empreinte

BIOMETRIC_STRONG représente une classe de biométrie, pas un sélecteur universel de capteur d'empreinte. L'empreinte doit être démontrée sur le modèle retenu ; le produit ne promet pas d'exclure tout autre capteur fort sur tous les téléphones. [S3]

6 Architecture et technologies

Composants proposés

Composant	Technologie proposée	Responsabilité
Application Android	Kotlin, Jetpack Compose, AndroidX Biometric	Association, affichage, biométrie et signature.
Credential Provider V2	C++ natif, COM, Windows SDK	Tuile Windows, contexte de connexion, sérialisation et résultat système.
Service Windows	C++ avec API Windows et bibliothèques maintenues	Échanges locaux, contrôle de la preuve, associations et accès aux secrets.
Configuration PC	C# et .NET LTS pris en charge	Assistant, diagnostic, révocation, historique et maintenance.
Communication	HTTPS avec TLS 1.3 et authentification mutuelle	Échanges chiffrés entre appareils associés.
Stockage PC	Fichiers protégés et DPAPI ; métadonnées structurées	Clés, secret Windows et associations.
Distribution	APK signé localement ; Windows selon politiques	Installation, mise à jour et traçabilité des versions.

Séparation des responsabilités

Le Credential Provider reste léger : pas de serveur réseau, pas de traitement biométrique, pas de requête bloquante sur le fil de l'interface Windows. Il communique avec le service par canal IPC local authentifié et à droits restreints. Le service peut démarrer avant la session utilisateur.

L'identité transport du téléphone et sa clé d'autorisation biométrique sont distinctes. La première permet d'établir le canal ; la seconde exige une biométrie fraîche pour signer chaque opération. Une connexion TLS valide ne constitue pas une autorisation de déverrouillage.

Réseau local

Port dédié proposé : 47863/TCP. Garder le profil Public ; limiter la règle au service, au port et à l'adresse du téléphone, et l'écoute à l'interface retenue. Actualiser une adresse modifiée. QR ou adresse manuelle ; pas de découverte générale. [S9]

Pas d'ouverture sur le routeur ni relais Internet. Un profil Public Windows ne prouve pas que le Wi-Fi est partagé avec des inconnus. Sur un réseau réellement partagé ou isolant les clients, refuser l'usage hors contexte explicitement approuvé. L'adresse IP est un filtre réseau ; l'identité cryptographique reste obligatoire.

Hypothèses à vérifier

Vérifier TLS 1.3, réseau préconnexion et protections du code. L'ouverture du compte Microsoft peut dépendre de Windows et d'Internet ; l'échange mobile reste local. Hyper-V, WSL et Docker ne sont pas requis.

7 Protocole de communication

Association et identité des appareils

Le PC et le téléphone utilisent des identités cryptographiques propres à l'association. Le QR code amorce la confiance par l'empreinte de la clé publique PC et un jeton aléatoire de 256 bits. Le code comparé sur les deux écrans est dérivé de la transcription authentifiée de l'échange ; il ne remplace pas le secret d'association. Limite de trois essais par jeton.

Après confirmation, chaque appareil enregistre la clé publique ou le certificat de son correspondant. Les identités sont épinglées ; une adresse IP, un nom mDNS ou un certificat inconnu ne permettent jamais de réassocier silencieusement un appareil.

Contenu signé de la demande

Champ	Exigence
protocol_version et action	Version explicite et action windows_interactive_logon ou windows_unlock.
request_id et nonce	Identifiant unique et nonce de 256 bits créé par un générateur cryptographique PC.
pc_id et pairing_id	PC destinataire et association autorisée.
account_sid et context_id	Compte précis et contexte créé par la tuile Windows active.
issued_at et expires_at	Heures informatives ; expiration imposée par le PC après 30 secondes.
decision	Valeur allow ; signature couvrant tous les champs et un préfixe de domaine propre au produit.

Signature et validation

Choix proposé : ECDSA P-256 avec SHA-256. Définir un encodage déterministe, par exemple CBOR déterministe, et une représentation de signature unique dans la spécification. Le dialogue biométrique autorise l'opération de signature de cette demande précise ; un simple booléen « succès biométrique » envoyé au PC est interdit.

Le PC vérifie canal, association, clé, signature, compte, contexte actif et expiration. La demande est consommée atomiquement avant soumission à Windows, même si Windows refuse ensuite. Une preuve dupliquée, tardive ou liée à un autre contexte est rejetée.

États et erreurs

États : créée, présentée, autorisée, consommée, puis connexion réussie ou refusée. Annulation, expiration, révocation ou changement de tuile sont terminaux. Une nouvelle tentative crée une nouvelle demande. Codes stables : EXPIRED, CANCELLED, REVOKED, INVALID_PROOF, WRONG_CONTEXT, PC_UNREACHABLE, WINDOWS_REJECTED et RESULT_UNKNOWN.

8 Intégration Windows et secret de connexion

Pont entre le téléphone et Windows

Le fournisseur reçoit la preuve vérifiée et prépare des identifiants compatibles avec le compte Microsoft ciblé. La sérialisation, le traitement du compte et les scénarios de connexion et déverrouillage doivent être démontrés ; un exemple limité aux comptes locaux n'est pas suffisant. Windows décide du résultat final. [S1, S6]

L'objectif reste d'éviter la saisie quotidienne du PIN sans supprimer Windows Hello. La piste avec secret récupérable utilise le mot de passe Microsoft, jamais son PIN. Un compte Microsoft sans mot de passe ne peut pas suivre cette piste ; aucune API supposée d'export ou de réutilisation du PIN n'est admise.

Provisionnement du secret

1. Après validation du jalon Microsoft, vérifier pendant une session ouverte que le secret correspond au compte lié. Une simple connexion réussie au site Microsoft ne prouve pas la compatibilité avec l'écran de connexion Windows.
2. Le transmettre une seule fois au service de confiance sur un IPC sécurisé. Ne jamais le mettre dans le QR, le téléphone, les arguments de processus ou les journaux.
3. Chiffrer le secret dans le contexte du service et protéger les fichiers par des ACL réservées à l'identité du service et aux administrateurs autorisés.
4. Lors d'une demande validée, déchiffrer juste avant sérialisation, restreindre les copies et effacer les tampons contrôlés après usage.

Protection et limite explicites

DPAPI en portée machine ne restreint pas à lui seul le déchiffrement à un service : tout utilisateur qui obtient le blob peut le déchiffrer sur cette machine. Le prototype privilégie une protection dans le contexte du service, avec ACL strictes ; toute variante en portée machine nécessite une justification de sécurité. [S5]

Un mot de passe Microsoft récupérable pourrait exposer le compte en ligne, pas seulement la session du PC. Son stockage nécessite un accord explicite et une revue. Le produit ne garantit pas de résister à un administrateur malveillant ou à Windows compromis. Le secret est chiffré et les copies contrôlées sont réduites puis effacées.

Reprise et isolation

Un arrêt du service, une DLL défectueuse ou une erreur réseau doivent laisser la connexion Windows habituelle disponible. Les comptes non associés ne reçoivent aucune autorisation. Un changement de compte, de session ou une reprise après redémarrage invalident les demandes précédentes.

9 Données et confidentialité

Inventaire minimal

Donnée	Emplacement	Conservation
Empreinte ou modèle biométrique	Gérés par le système du téléphone ; non collectés par l'application.	Aucune copie dans le produit.
Clé privée d'autorisation	Android Keystore ; non exportable ; protection matérielle exigée pour les appareils certifiés.	Jusqu'à suppression ou invalidation.
Clés de transport et identité PC	Stockages protégés Android et service Windows.	Durée de l'association ou de l'installation.
Clés publiques et association	PC et téléphone ; identifiants aléatoires, SID du compte lié et nom lisible.	Jusqu'à révocation ou suppression.
Mot de passe Windows	PC uniquement ; secret chiffré, usage réservé au service.	Jusqu'à remplacement ou suppression de l'association.
Demandes actives	Mémoire PC ; pas de restauration après redémarrage.	30 secondes au maximum.
Journal de sécurité	PC ; date, type, association pseudonyme, résultat et code d'erreur.	30 jours, maximum 1 000 événements.

Cycle de vie des clés Android

Android Keystore fournit des clés non exportables et peut les lier à du matériel sécurisé et à une authentification. La capacité effective du téléphone doit être contrôlée, pas supposée. Les clés biométriques sont configurées pour une autorisation par opération et une invalidation lors de changements d'enrôlement applicables. [S4]

La clé d'autorisation n'entre dans aucune sauvegarde Android. La restauration de l'application exige une nouvelle association. Une révocation PC supprime la confiance immédiatement même si le téléphone est hors ligne ; la suppression des données sur le téléphone seul ne suffit pas à assurer cette révocation côté PC.

Transparence

Pas de compte cloud, publicité, collecte analytique ou transmission automatique de diagnostics dans la première version. L'assistant présente les données conservées, le secret Windows et les limites de sécurité. Un export de diagnostic est volontaire et expurgé ; aucun secret, jeton d'association ou contenu signé complet n'y apparaît.

La désinstallation et la suppression d'une association effacent les secrets associés et les métadonnées maîtrisées. L'effacement physique absolu sur SSD ou dans les sauvegardes externes n'est pas garanti. Avant une diffusion commerciale, les obligations de confidentialité sont étudiées selon les pays et publics concernés ; aucune conformité juridique globale n'est affirmée ici.

10 Exigences de sécurité et menaces

Le modèle de menace couvre un attaquant sur le réseau local, un téléphone non associé, un utilisateur Windows standard et une perte du téléphone. Une compromission administrateur ou noyau sort des garanties du produit, mais doit être documentée lors de la revue.

ID	Menace	Mesure exigée
S01	Capture et rejeu d’une autorisation	Nonce unique, expiration PC, usage unique atomique et liaison au compte et contexte.
S02	Usurpation du PC ou interception	Identités épinglées, TLS mutuel, comparaison du code d’association et refus du changement de clé.
S03	Téléphone perdu	Biométrie forte à chaque signature, révocation depuis Windows et secours local.
S04	Commande réseau forgée	Aucune ouverture sur une simple réponse allow ; signature et contrôles complets obligatoires.
S05	Mauvais compte ou session	SID fixe, contexte actif contrôlé et invalidation quand la tuile change.
S06	Vol du secret PC	ACL, identité de service dédiée, chiffrement, durée minimale en mémoire et logs expurgés.
S07	Détournement de l’IPC	ACL du canal, contrôle de l’appelant et autorisation séparée des opérations d’administration.
S08	Demandes répétées ou saturation	Quotas, limites de taille, délais réseau et une seule demande active par compte.
S09	Mise à jour malveillante	Paquets signés, intégrité vérifiée et rejet de versions non autorisées.
S10	Ajout d’une biométrie ou restauration	Invalidation et réassociation ; aucune récupération automatique de clé.
S11	Blocage de l’accès au PC	Méthodes Windows conservées ; rollback et tests de crash.
S12	Approbation d’une mauvaise demande	Initiation explicite sur le PC, affichage du compte et code de correspondance mobile.

Limites et règles complémentaires

La première version refuse le recours au PIN du téléphone dans son flux d’autorisation. Android garde ses propres règles de verrouillage biométrique ; après redémarrage du téléphone, l’utilisatrice peut devoir le déverrouiller normalement avant d’utiliser l’application.

La présence sur le même Wi-Fi ne prouve pas la proximité physique. Un attaquant capable de relayer des échanges ou de tromper l’utilisatrice reste une menace à étudier. L’interface exige une vérification consciente ; le produit n’est pas présenté comme une authentification FIDO certifiée ou comme une solution universellement résistante au phishing.

11 Qualité performances et compatibilité

Objectifs mesurables proposés

Critère	Cible de recette	Mesure
Après validation biométrique	Résultat Windows affiché en 3 secondes au plus au 95e percentile.	100 tentatives, réseau local stable, téléphone ouvert et PC prêt.
Affichage de la demande	2 secondes au plus au 95e percentile.	À partir de l'ouverture du PC associé sur le mobile.
Taux de succès nominal	Au moins 98 succès sur 100 essais.	Hors échec biométrique humain et compte invalide ; causes consignées.
Expiration	30 secondes ; aucune preuve tardive acceptée.	Horloge monotone PC, tests de retard et changement d'heure.
Ressources service	CPU moyen au repos inférieur à 1 % et mémoire cible inférieure à 100 Mo.	PC de référence, mesure sur 10 minutes.
Résilience	Aucun blocage de l'accès Windows de secours.	Crash, arrêt du service, panne réseau et redémarrage.
Disponibilité hors Internet	Échanges locaux sans Internet ; connexion Microsoft hors ligne validée séparément.	Routeur actif, Internet coupé ; limites Windows consignées.
Limites protocole	Message maximum 16 Ko ; 1 demande active ; 3 nouvelles demandes par minute et compte.	Charges excessives et concurrence contrôlées.

Matrice de certification

Tester la version Windows personnelle et le compte Microsoft sans activer Hyper-V. Inclure réseau Public, réseau préconnexion, veille et redémarrage. Conserver Defender, BitLocker et les protections de code. Les essais du fournisseur se font d'abord sur un PC de test séparé ; un autre compte sur le même PC ne constitue pas un isolement système.

Pour Android, tester au minimum les versions 11, 13 et une version récente prise en charge, sur deux fabricants. La présence d'un capteur ne suffit pas : canAuthenticate, signature biométrique par opération et protection matérielle doivent être validés. Les appareils non compatibles affichent un refus clair.

Restrictions assumées

L'application mobile doit être ouverte au moment de la demande ; la première version ne garantit pas l'exécution permanente en arrière-plan. Si le réseau n'est pas disponible avant ouverture de session après redémarrage, la connexion de secours s'impose. Le support de la reprise de veille inclut la reconnexion du réseau, sans autoriser une ancienne demande.

12 Installation maintenance et exploitation

Installation Windows

1. Développer d'abord le protocole et le mobile sans modifier la connexion Windows. Tester ensuite le fournisseur sur un autre PC Windows, sans Hyper-V. Préparer sauvegarde, récupération et rollback ; un simple compte secondaire n'isole pas une DLL chargée par LogonUI.
2. Vérifier version Windows, architecture x64, type de compte, protections actives et droits administrateur.
3. Installer les fichiers dans un dossier protégé ; enregistrer le service et le Credential Provider puis créer les règles pare-feu limitées.
4. Contrôler signatures, ACL et démarrage du service. En cas d'erreur, annuler les modifications de l'installation.
5. Associer le téléphone après une connexion Windows normale, puis tester verrouillage, veille et redémarrage. Ne pas désactiver les autres fournisseurs d'identifiants.

Mises à jour

Versions du protocole explicites et intégrité des mises à jour vérifiée. L'APK est signé avec une clé locale gratuite. Pour Windows, examiner les politiques : une signature personnelle n'est pas équivalente à une signature reconnue par Smart App Control. Une protection bloquante suspend le pilote du projet ; aucune désactivation automatique ni achat imposé. [S13]

Ne pas effectuer une mise à jour pendant une demande active. Les migrations conservent les associations uniquement si l'intégrité et la compatibilité sont vérifiées. Toute modification du format de secret ou de son identité de service requiert des essais de redémarrage et de récupération.

Diagnostic local

- Afficher état du service, version des composants, disponibilité du réseau et dernier code d'erreur.
- Proposer un test de communication sans ouvrir de session ni exposer un secret.
- Distinguer absence de réseau, clé invalide, association révoquée et identifiants Windows refusés.
- Ne jamais recommander de désactiver Defender, BitLocker, l'authentification Windows ou les protections de sécurité pour faire fonctionner le produit.

Désinstallation et assistance

Révoquer les associations, arrêter les demandes, désenregistrer uniquement le fournisseur ajouté, retirer service et règles pare-feu créées, puis effacer les secrets du produit. Après désinstallation et redémarrage, le compte doit rester accessible normalement.

Le guide de récupération explique l'accès par mot de passe ou PIN Windows, la désactivation du seul composant tiers et la restauration depuis l'environnement de test. Le support ne demande jamais le mot de passe ou l'empreinte de l'utilisatrice. Toute intervention à distance sort du périmètre standard et exige son accord.

13 Plan de recette fonctionnelle

Chaque test est consigné avec configuration, version des composants, résultat, preuve et anomalie éventuelle. Utiliser des comptes de test et des secrets fictifs pendant le développement.

Test	Scénario	Résultat attendu
T01	Installation sur Windows cible	Composants installés ; connexion Windows habituelle accessible.
T02	Compte ou téléphone non compatible	Tester mot de passe absent, Hello uniquement et code bloqué ; refus clair sans changer les protections.
T03	Association nominale	Clés liées au compte après double confirmation ; premier essai réussi.
T04	QR expiré ou code différent	Association refusée ; aucun secret ou droit conservé.
T05	Connexion après redémarrage	Ouverture réelle de la session visée lorsque le réseau préconnexion est disponible.
T06	Verrouillage et sortie de veille	Demande fraîche ; ouverture du même compte ; ancienne preuve inutilisable.
T07	Biométrie réussie	Une seule signature et une seule soumission Windows ; résultat final exact.
T08	Biométrie refusée ou annulée	PC toujours verrouillé ; pas de signature ni ouverture automatique.
T09	Téléphone absent ou batterie vide	Connexion de secours possible immédiatement.
T10	Réseau coupé pendant le flux	Refus ou résultat inconnu explicite ; aucune répétition automatique de soumission.
T11	Mot de passe Windows changé	Refus Windows ; fonction suspendue ; actualisation authentifiée possible.
T12	Ajout de biométrie ou réinstallation	Clé invalidée selon configuration ; nouvelle association nécessaire.
T13	Révocation avec mobile hors ligne	Toute preuve de l’ancien téléphone refusée dès révocation PC.
T14	Changement de compte actif	Demande précédente annulée ; pas d’accès à un autre compte.
T15	Crash service ou fournisseur	Autres options Windows utilisables ; reprise sans ancienne demande.
T16	Mise à jour puis désinstallation	Rollback testé ; accès normal après retrait des composants.

Traçabilité

Les tests T01 à T26 couvrent les exigences F01 à F15. Le rapport final contient une matrice explicite exigence → tests → preuves. Une capture d’écran seule ne prouve pas qu’une session a été ouverte ; le test vérifie aussi le compte réellement connecté et le résultat système. Le test T02 inclut mot de passe absent, Hello uniquement et politique de code bloquante ; T05 et T10 incluent le profil Public.

14 Recette sécurité et acceptation

Test	Attaque ou défaillance	Critère de réussite
T17	Rejeu après succès, refus ou expiration	Toutes les copies sont rejetées ; aucune seconde soumission Windows.
T18	Modification du SID, nonce ou contexte	Signature ou contexte invalide ; aucune ouverture.
T19	Serveur ou téléphone usurpé	Canal rejeté sans épinglage correct ; association non modifiée.
T20	Accès depuis utilisateur Windows standard	Impossible de lire les secrets ou d'utiliser l'IPC pour obtenir une ouverture.
T21	Deux preuves simultanées	Consommation atomique : au plus une soumission.
T22	Messages malformés ou trop volumineux	Rejet contrôlé, aucune panne du service ou de LogonUI.
T23	Changement d'heure et redémarrage	Durée imposée par le PC ; demandes préexistantes inutilisables.
T24	Historique, diagnostics et effacement	Historique lisible et effaçable ; aucun secret en clair dans fichiers, logs ou export.
T25	Charge et requêtes répétées	Quotas appliqués ; connexion Windows de secours réactive.
T26	Paquet de mise à jour altéré	Mise à jour refusée ; installation courante encore utilisable.

Conditions de livraison de la première version

- Toutes les exigences P0 ont une preuve de réussite sur la matrice annoncée.
- Aucune anomalie critique ou majeure ouverte concernant accès non autorisé, fuite de secret ou impossibilité de récupération.
- Les seuils de performance sont atteints dans les conditions de mesure définies ; les exclusions sont consignées.
- Le prototype Windows a validé démarrage, verrouillage et veille sur la cible. Le réseau préconnexion et ses limites sont documentés.
- Les sources, binaires autorisés par les politiques existantes, guides et rapports sont livrés sans achat imposé.
- La conservation du secret Windows et les limites de protection ont été explicitement acceptées pour le périmètre livré.

Classification des anomalies

Critique : ouverture non autorisée, exposition d'un secret ou blocage sans récupération. Majeure : fonction P0 inutilisable sur une configuration certifiée. Mineure : défaut de présentation ou cas secondaire avec contournement sûr. Les anomalies critiques et majeures bloquent la mise en production ; les mineures nécessitent une décision écrite et une date de correction.

15 Organisation planning et estimation

Les charges suivantes sont des estimations initiales de temps de travail pour un prototype puis une première version personnelle. Elles dépendent de l'expérience en intégration Windows et de la difficulté du compte Microsoft. Elles seront révisées après le jalon de faisabilité ; elles ne représentent aucun coût à payer à un prestataire.

Lot	Travaux et sortie attendue	Charge
L0	Confirmer appareils, type de compte, secours et acceptation du secret local.	2 à 3 j
L1	Prototype Microsoft sur PC séparé sans Hyper-V ; logon, veille, Public et politiques de code.	5 à 10 j
L2	Spécification du protocole, modèle de menace, association et gestion des clés.	4 à 7 j
L3	Application Android, parcours et signature biométrique.	6 à 10 j
L4	Service, Credential Provider et configuration Windows complets.	10 à 18 j
L5	Intégration, installeurs, signatures et documentation.	5 à 8 j
L6	Recette sur appareils, revue sécurité et corrections.	8 à 15 j
Total	Effort cumulé, avant réserve.	40 à 71 j

Ordre de réalisation

L0 puis L1 constituent le passage obligatoire. L2 précède l'intégration ; L3 et L4 peuvent avancer en parallèle avec un protocole stabilisé. L5 et L6 suivent une version intégrée. Estimation initiale pour une personne à temps plein : environ 10 à 18 semaines, avec réserve de 20 à 30 %, hors attente de matériel. Un rythme personnel à temps partiel peut allonger ce délai ; aucune échéance ferme n'est annoncée.

Budget personnel

L'utilisatrice développe elle-même avec VS Code ; budget logiciel supplémentaire visé : 0 Ar. Pas de prestataire, hébergement, publication sur store ni certificat commercial imposés. Prévoir le temps de développement et les téléchargements. Si les protections Windows exigent une solution payante, interrompre cette piste et réévaluer la faisabilité gratuite.

Risques de projet

Risque principal : obtenir une connexion Microsoft acceptée avec les protections actuelles et zéro achat. Autres risques : réseau préconnexion, profil Public, biométrie Android et récupération après panne. Les charges restent indicatives et seront révisées après le jalon Microsoft ; aucun résultat de compatibilité n'est annoncé avant essai.

16 Livrables responsabilités et décisions

Livrables du projet

- Dépôt source complet avec historique utile, instructions de compilation reproductible et licences des dépendances.
- Application Android signée localement et installeur Windows dont le chargement est validé avec les politiques existantes ; versions, empreintes des binaires et procédure de mise à jour. Aucun certificat commercial imposé.
- Spécification du protocole : formats, champs, encodage signé, clés, erreurs, états et règles de compatibilité.
- Documentation d'architecture et de sécurité : stockage du secret, IPC, menaces, limites et procédures de révocation.
- Rapport de preuve de faisabilité et rapport de recette avec matrice appareils et traçabilité F01 à F15 et T01 à T26.
- Guides utilisateur : installation, première association, usage, changement de téléphone, mise à jour du secret, secours et désinstallation.
- Guide développeur et d'exploitation : configuration, logs expurgés, dépendances, release, rollback et récupération.

Propriété et maintenance

Pour cet usage personnel, documenter les licences des dépendances et garder le dépôt complet sous contrôle de l'utilisatrice. Les clés de signature restent hors du dépôt. Aucun contrat de prestataire ni publication n'est nécessaire ; la maintenance revient à la personne qui réalise le projet.

La maintenance comprend les essais après nouvelles versions Windows et Android ciblées, les mises à jour de dépendances, les avis de sécurité et la récupération. L'utilisatrice décide de son rythme de maintenance ; aucune prestation externe ni garantie de support payante ne sont requises.

Décisions à confirmer avant le lot L1

Décision	Hypothèse actuelle
Système et compte PC	Compte Microsoft conservé ; Windows et connexion à vérifier.
Modèle du téléphone	Android 11 ou plus récent ; empreinte forte et clé matérielle à vérifier.
Secret Windows local	Accepté uniquement après présentation du risque et de la méthode de protection.
Réseau	Profil Public conservé ; accès limité à l'IP du téléphone.
Distribution	Usage personnel uniquement ; zéro achat et aucune publication exigée.
Évolution	iPhone, Bluetooth et multiappareils hors MVP.

Cette version sert à réaliser un projet personnel gratuit dans VS Code. Le compte Microsoft est conservé, Hyper-V reste désactivé et le profil réseau Public est maintenu. Le déverrouillage reste conditionné à un prototype validé ; le cahier des charges ne garantit pas la compatibilité du PC à lui seul.

17 Références et glossaire

Références techniques officielles consultées le 12 octobre 2026. Les choix de protocole, objectifs de performance et estimations de charge sont des propositions de conception propres à ce document. Les sources étayent les possibilités et limites des plateformes, sans valider à elles seules l'ensemble de l'architecture.

S1 Microsoft Learn - Credential providers in Windows

S2 Microsoft Learn - Windows Hello and Companion Device Framework

S3 Android Developers - Show a biometric authentication dialog

S4 Android Developers - Android Keystore system

S5 Microsoft Learn - CryptProtectData function

S6 Microsoft Learn - CREDENTIAL_PROVIDER_USAGE_SCENARIO

S7 Microsoft Learn - Dynamic lock

S8 Microsoft Learn - Support for passkeys in Windows

S9 Microsoft Learn - Windows Firewall Rules

S10 Microsoft Support - Go passwordless in Windows

S11 Microsoft - Visual Studio Community

S12 Android Developers - Build your app from the command line

S13 Microsoft Learn - Sign your app for Smart App Control compliance

Glossaire

Terme	Signification
Credential Provider	Composant présentant une méthode de saisie ou collecte d'identifiants dans Windows.
SID	Identifiant de sécurité du compte Windows ; évite de se fier seulement au nom affiché.
Nonce	Valeur aléatoire propre à une demande, utilisée pour empêcher son rejeu.
Keystore et DPAPI	Mécanismes Android et Windows de protection des clés ou données sensibles.
IPC et ACL	Communication entre processus et règles contrôlant qui peut accéder à une ressource.
TLS mutuel	Canal chiffré dans lequel les deux appareils prouvent leur identité.
MVP et POC	Première version utile du produit et preuve de faisabilité technique.

Principe final de conception : la biométrie autorise une clé du téléphone ; la clé autorise une demande précise ; Windows reste responsable d'accepter l'ouverture de session.

18 Configuration personnelle et budget gratuit

Contraintes confirmées par l'utilisatrice : usage personnel, VS Code, aucune dépense souhaitée, compte Microsoft conservé, Hyper-V désactivé et Wi-Fi en profil Public. La version Windows précise, le téléphone et les options de connexion restent à vérifier.

Outils sans achat

Utiliser VS Code comme éditeur. Le compilateur C++ MSVC et le Windows SDK servent à la partie Windows, avec les droits gratuits de Visual Studio Community pour un développeur individuel. Android utilise JDK, SDK et Gradle ; la compilation peut être lancée dans le terminal de VS Code. Aucun Hyper-V n'est nécessaire à ces composants. [S11, S12]

Installer l'APK directement sur le téléphone Android avec une clé de signature locale ; pas de compte de publication Play Store. Les échanges PC et téléphone sont locaux et n'exigent ni API payante, ni domaine, ni serveur hébergé. Le budget nul vise les logiciels et services supplémentaires ; la connexion Internet existante et le matériel sont supposés disponibles.

Compte Microsoft et ouverture de session

Distinguer deux états : le compte Microsoft peut ne plus avoir de mot de passe ; Windows peut aussi proposer uniquement Windows Hello sur cet appareil. La seconde option retire la méthode de connexion par mot de passe visible. Le prototype examine les deux cas sans les confondre et sans les modifier automatiquement. [S10]

Avant tout stockage, vérifier si un mot de passe Microsoft existe et si le chemin système envisagé l'accepte pour ce compte. Si la piste échoue, poursuivre uniquement la démonstration réseau et biométrique ; le déverrouillage de Windows reste non validé. Ne pas convertir le compte principal ni collecter son PIN.

Profil Public et tests sans Hyper V

Garder le pare-feu actif. Prévoir une exception entrante ciblée sur le service, le port et l'adresse du téléphone, limitée à l'interface retenue. Aucun partage Windows général ni découverte réseau globale n'est requis. Si le Wi-Fi est réellement partagé avec des inconnus ou isole les clients, diagnostiquer ce contexte avant d'autoriser l'usage. [S9]

Tester le réseau et la biométrie sans enregistrer de fournisseur d'identifiants. La connexion Windows se teste ensuite sur un PC séparé avec récupération préparée. Hyper-V reste désactivé. Si aucun environnement de test adéquat n'est disponible, le prototype réseau peut avancer ; l'installation sur le PC principal attend cette validation.